

TrustSecAI: Integrating Retrieval Grounded Threat Intelligence, XAI, and Domain Adaptive Language Models for Security Incident Assessment

Abstract

Modern Intrusion Detection Systems and ML based security classifiers are effective at identifying malicious network activity, but often provide limited insight into the reasoning behind their predictions and little contextual information for security analysts. This can reduce trust in automated systems and increase the effort required for incident investigation and response.

This project proposes TrustSecAI, an AI assisted security incident analysis framework that combines ML based attack detection, XAI, Retrieval Augmented Generation, and lightweight domain adaptive LLMs to generate comprehensive and actionable security assessments.

The framework utilizes network traffic datasets such as CICIDS2017 to train attack detection models capable of identifying malicious activity. Explainability techniques such as SHAP or LIME are then used to highlight the most influential features contributing to each prediction. Simultaneously, the retrieval layer gathers relevant cybersecurity knowledge from sources such as MITRE ATT&CK, vulnerability databases, threat intelligence reports, and security playbooks.

The domain adapted LLM receives the classifier's prediction, feature level explanations, and retrieved threat intelligence to generate a structured incident report containing the attack interpretation, severity assessment, potential consequences, mitigation strategies, and confidence aware contextual analysis. In addition to explaining classifier decisions, the system acts as an AI security analyst by providing a secondary contextual assessment based on the available evidence and threat intelligence.

The project will evaluate the contribution of explainability, retrieval grounding, and domain adaptation toward improving the factual accuracy, interpretability, trustworthiness, reducing hallucinations and actionability of AI generated security assessments. The overall objective is to develop a framework that transforms raw security alerts into meaningful decision support information for SOC analysts.

Datasets

CICIDS2017 - ~2 GB

UNSW-NB15

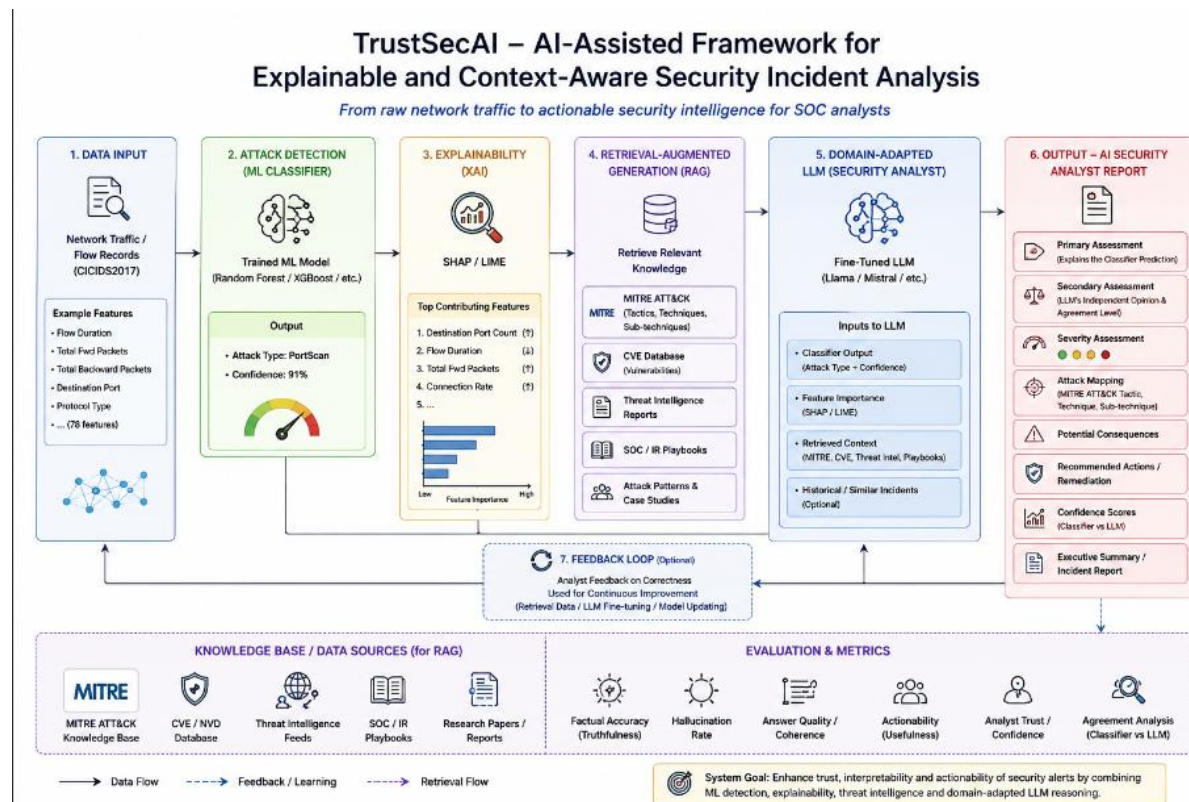
MITRE ATT&CK (For Retrieval)

CVE/NVD (For Retrieval)

Threat Intelligence Reports (For Retrieval)

SOC Playbooks (For Retrieval)

Tentative HLD



Novelty

Traditional IDS and ML based security classifiers primarily focus on identifying malicious activity and generating alerts. While explainability techniques such as SHAP and LIME can provide feature level insights into model predictions, they often fail to deliver the broader contextual understanding required by SOC analysts for effective decision making.

The proposed framework introduces a novel AI assisted security analysis layer that combines ML based attack detection, XAI, RAG, and domain adaptive LLMs into a unified decision support system. Instead of relying solely on attack classification, the framework enriches alerts with contextual threat intelligence retrieved from sources such as MITRE ATT&CK, CVE databases, threat reports, and security playbooks.

A key contribution of the proposed system is the generation of a Secondary Contextual Assessment, where a retrieval grounded and domain adapted LLM acts as an AI security analyst. The LLM interprets classifier predictions, analyses feature level explanations, incorporates external threat intelligence, evaluates potential consequences, and generates confidence aware recommendations and incident reports for analysts.

Unlike traditional IDS pipelines that stop at attack classification, the proposed framework investigates the use of a retrieval grounded AI analyst capable of generating confidence aware contextual assessments and actionable incident intelligence for SOC analysts.

The project further investigates how retrieval grounding, explainability, and domain adaptation collectively influence the factual accuracy, interpretability, trustworthiness, and actionability of AI-generated security assessments. By transforming raw IDS alerts into context-rich security intelligence,

the framework aims to improve analyst understanding, decision confidence, and incident response effectiveness.

Example Scenario

Input:

Flow Duration: 1200 ms

Destination Ports Contacted: 850

Connection Attempts: 1200

Packet Rate: High

Classifier Output:

Attack Type: PortScan

Confidence: 91%

Output:

Existing systems:

Alert Generated

Attack Type: PortScan

Confidence: 91%

Proposed system:

Primary assessment

Attack Type: PortScan

Classifier Confidence: 91%

Explanation:

The prediction was primarily influenced by an unusually high number of destination ports contacted within a short period of time, which is characteristic of reconnaissance activity.

Retrieved threat intelligence

MITRE ATT&CK Mapping: T1046 – Network Service Discovery

Tactic: TA0007 – Discovery

Secondary assessment

The observed behavior is consistent with reconnaissance activity commonly performed before exploitation attempts.

Retrieved threat intelligence indicates that similar scanning behavior is frequently observed during the early stages of intrusion campaigns.

Severity assessment: Medium

Potential consequences

1. Network Mapping
2. Service Enumeration
3. Preparation for Exploitation

Recommended remedial actions

- Investigate Source IP
- Review Authentication Logs
- Monitor for Follow-Up Activity
- Restrict Unnecessary Exposed Services

Incident summary

The detected activity aligns with MITRE ATT&CK Technique T1046 (Network Service Discovery). The attack appears to be reconnaissance-oriented and may indicate preparation for subsequent intrusion attempts. Immediate investigation and continued monitoring are recommended.

Roadmap

Timeline	Activities	Expected Deliverable
Week 1	Collect and study CICIDS2017, UNSW-NB15, MITRE ATT&CK, CVE/NVD, CAPEC, Threat Intelligence Reports, and SOC Playbooks. Perform data preprocessing, feature engineering, train baseline classifiers (Random Forest/XGBoost), and integrate SHAP/LIME for explainability.	Working IDS pipeline with baseline performance metrics and XAI explanations.
Weekend 1	Install and configure Neo4j. Design GraphRAG schema and entity relationships. Prepare cybersecurity corpus for LoRA fine-tuning (ATT&CK, CVE, CTI reports, playbooks, synthetic incident reports).	Graph schema finalized and fine-tuning dataset prepared.
Week 2	Begin LoRA fine-tuning of LLaMA 3.1 8B on university workstations. In parallel, construct the GraphRAG pipeline using Neo4j and ingest ATT&CK, CVE, CAPEC, and CTI data.	Functional GraphRAG system and initial domain-adapted LLM checkpoint.
Weekend 2	Complete pending GraphRAG ingestion tasks, validate retrieval quality, and monitor fine-tuning progress.	Stable GraphRAG retrieval and finalized fine-tuned model.
Week 3	Integrate GraphRAG with the fine-tuned LLM to create the AI Security Analyst. Generate contextual incident reports using classifier outputs, SHAP explanations, and retrieved threat intelligence. Begin implementation of Classifier-LLM Agreement Analysis.	End-to-end TrustSecAI prototype with contextual incident report generation.
Weekend 3	Refine Agreement Analysis module and prepare ATT&CK-based reasoning workflows for Attack Chain Prediction.	Attack-chain prediction design and agreement-analysis framework ready.
Week 4	Implement Attack Chain Prediction Agent using GraphRAG and ATT&CK relationships. Complete Agreement Analysis, perform ablation studies, evaluate system performance, and conduct end-to-end testing.	Fully integrated TrustSecAI framework with all proposed novelties implemented.

Timeline	Activities	Expected Deliverable
Weekend 4	Final documentation, report writing, PPT preparation, result visualization, and demonstration setup.	Final project report, presentation, and demo-ready system.